

# Badi

منصة حوكمة الأمن السيبراني والامتثال للمؤسسات

## حزمة أدلة التدقيق

Riyadh Regulated Financial Enterprise

Identity and Access Management Control Readiness Assessment التقييم  
Saudi cybersecurity baseline with metadata-only ISO/IEC 27001 mapping النطاق  
11:51 19-09-2026 تاريخ التوليد  
1.0 الإصدار  
Noura AlFahad المالك  
سري التصنيف

بيانات الوثيقة وضبط الإصدار

|                                                                            |                 |
|----------------------------------------------------------------------------|-----------------|
| Riyadh Regulated Financial Enterprise                                      | المنشأة         |
| Riyadh Regulated Financial Enterprise                                      | المستأجر        |
| Financial Services                                                         | القطاع          |
| Identity and Access Management Control Readiness Assessment (قيد المراجعة) | التقييم         |
| 66e94f54-3a50-4f35-9367-ed591473ea08                                       | معرف الوثيقة    |
| سري                                                                        | التصنيف         |
| 1.0                                                                        | الإصدار         |
| Noura AlFahad                                                              | المالك          |
| 11:51 19-09-2026                                                           | تاريخ التوليد   |
| 6                                                                          | عدد الضوابط     |
| مسودة مولدة • داخلي • تتطلب مراجعة بشرية                                   | المصدر والترخيص |

الأطر المرتبطة

CIS-CONTROLS 8.1 • DORA metadata-2026 • GDPR metadata-2026 • ISO-22301 metadata-2026 • ISO-31000 metadata-ISO-IEC-27001 2022 • ISO-IEC-27002 2022 • ISO-IEC-27005 metadata-2026 • ISO-IEC-27701 metadata-2026 • 2026 • NCA-CCC metadata-2026 • NCA-DCC metadata-2026 • NCA-ECC 2-2024 • NIS2 metadata-2026 • NIST-CSF 2.0 • PCI-DSS 4.0.1 • SAMA-CSF metadata-2026 • SOC2 metadata-2026

إشعار المراجعة الإلزامي

هذه حزمة أدلة مُولّدة كمسودة، وتتطلب مراجعة واعتماداً من مختصّي الامتثال والشؤون القانونية والأمن السيبراني المخولين قبل الاستخدام التشغيلي أو تقديمها كدليل تدقيق. لا تمثل ادعاءً بالامتثال الكامل أو الحصول على شهادة. تعكس هذه الحزمة فقط البيانات التي يحقّ للمستخدم المُولّد الاطلاع عليها ضمن نطاق صلاحياته؛ غياب عنصر هنا لا يعني عدم وجوده في المنشأة.

ملخص الجاهزية

|                |                |                    |                   |                   |
|----------------|----------------|--------------------|-------------------|-------------------|
| جاهزية التدقيق | إجمالي الضوابط | فجوات عالية مفتوحة | أدلة قيد المراجعة | غير مؤهلة للتدقيق |
| محدودة         | 6              | 1                  | 2                 | 6                 |

واجهات المنصة

لقطات حية من مساحة عمل المنشأة نفسها؛ الأرقام الظاهرة في الواجهات تطابق سجلات هذا التقرير.

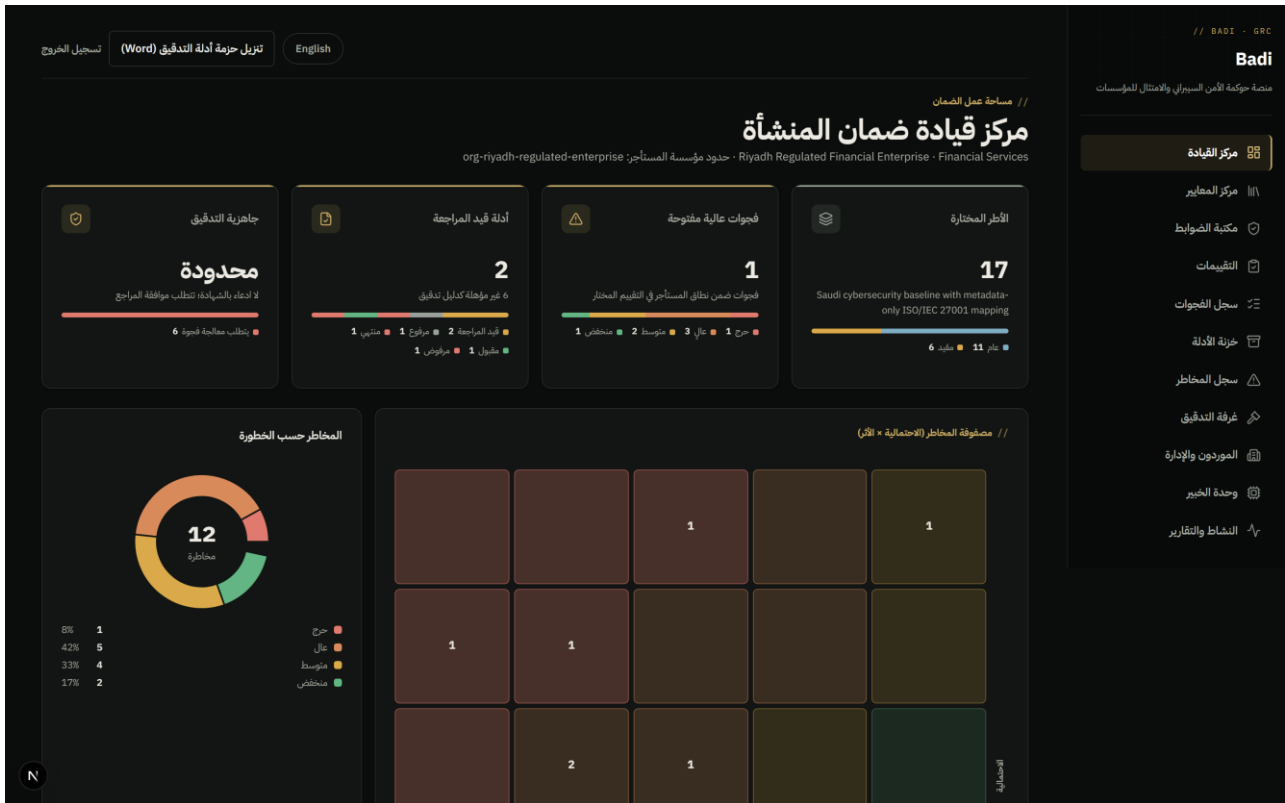


FIG 01 مركز قيادة ضمان المنشأة

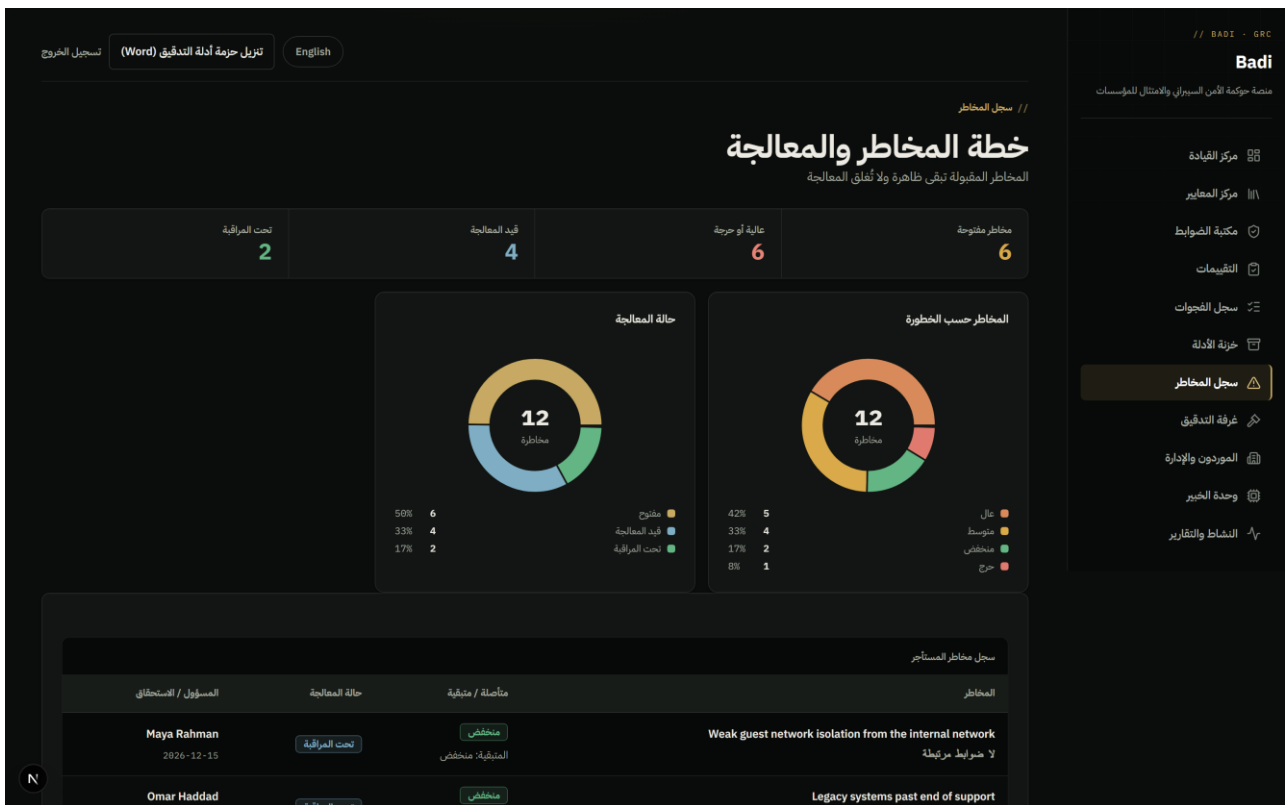
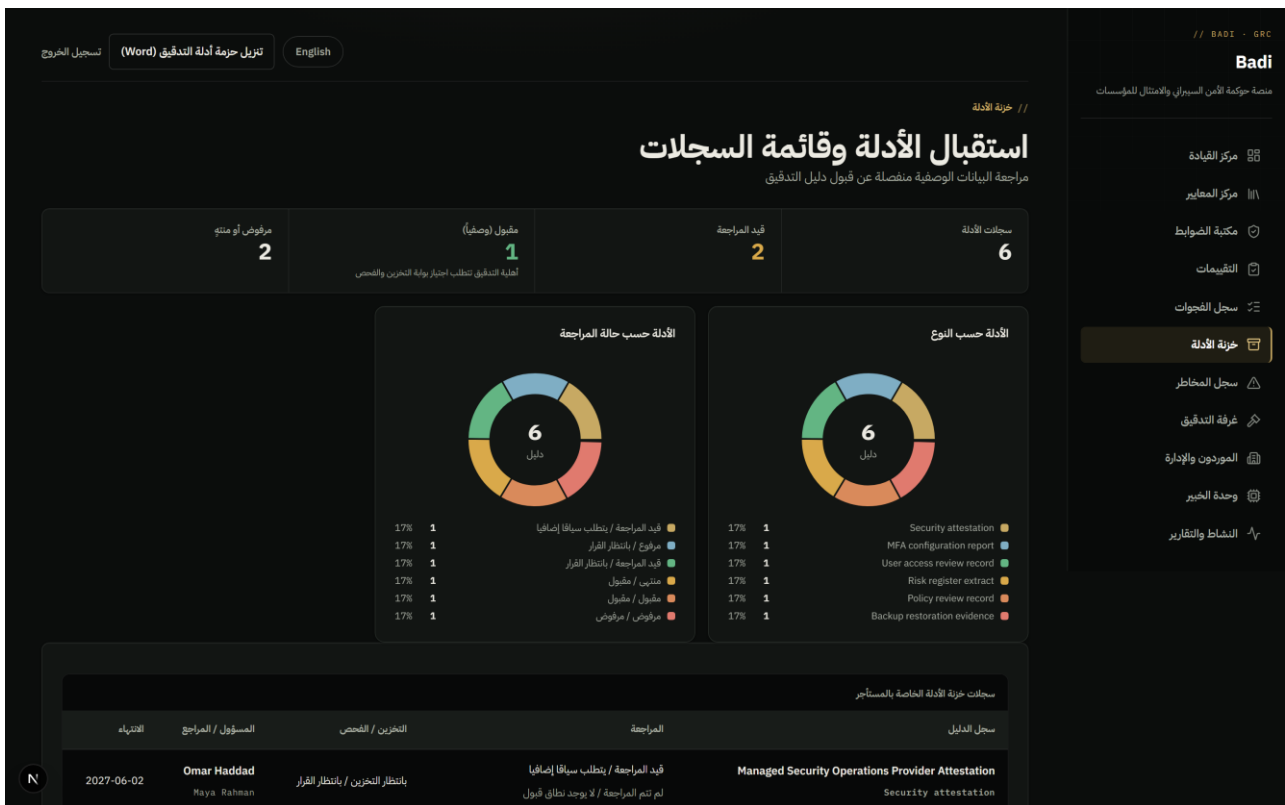
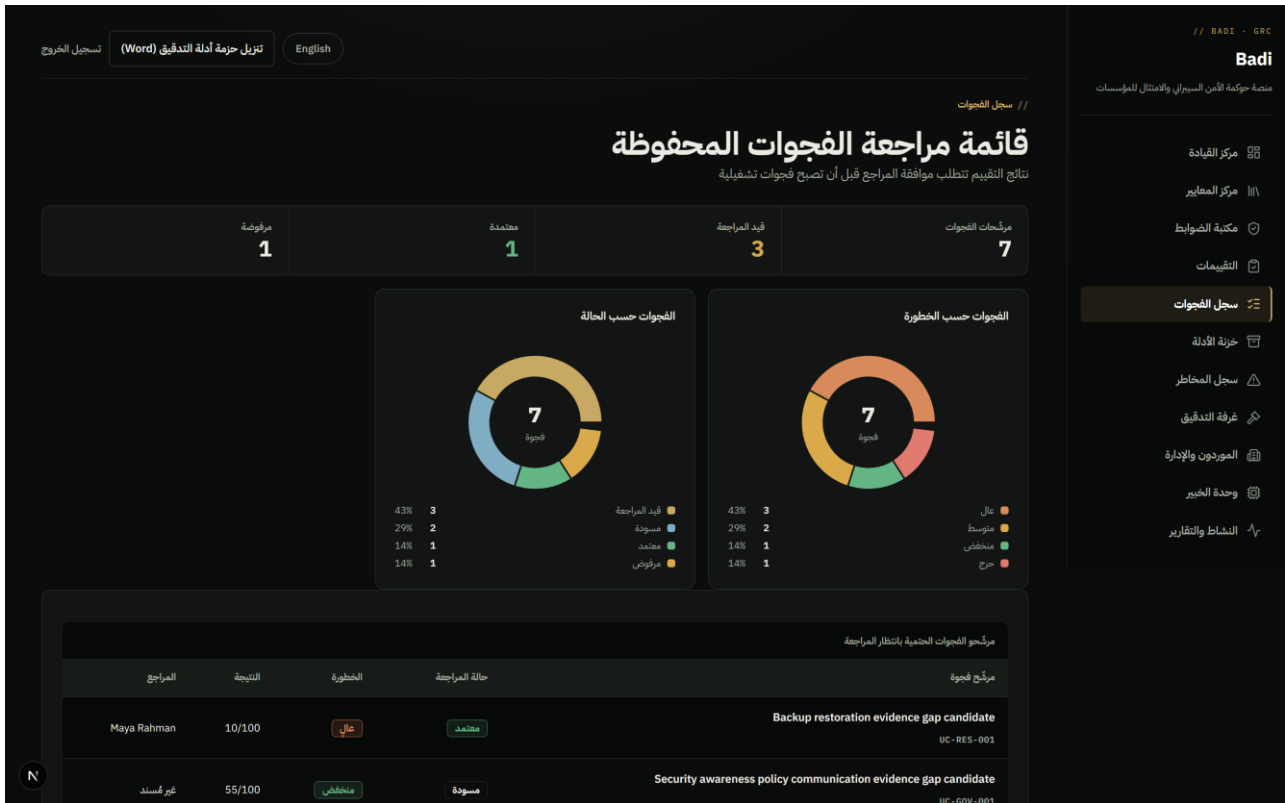
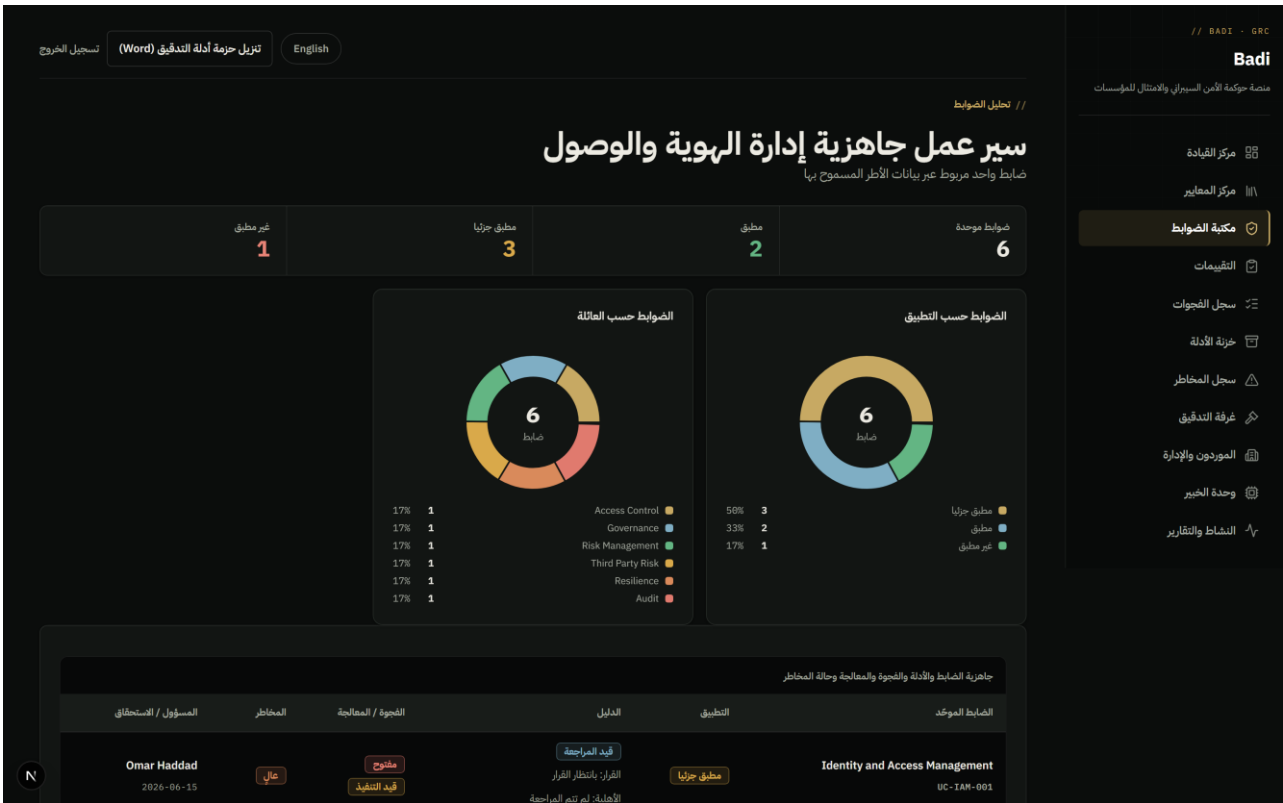
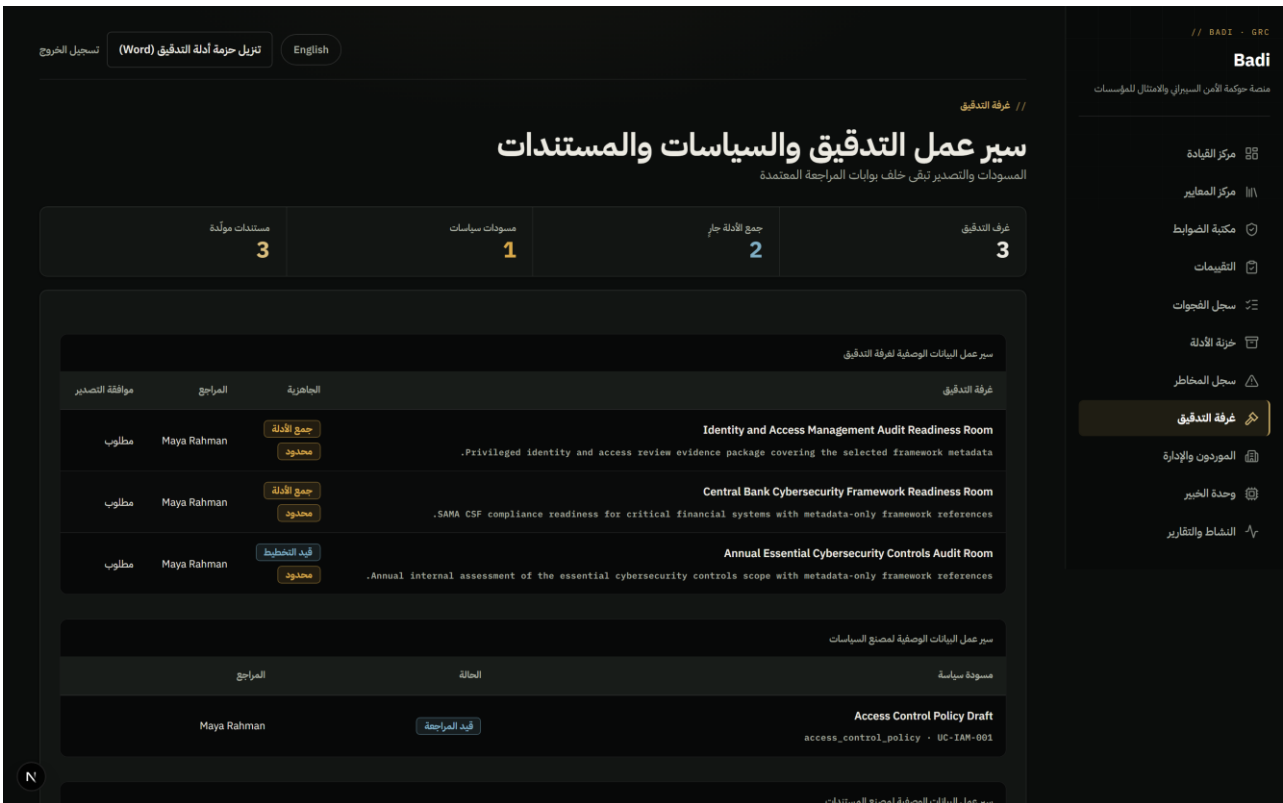


FIG 02 سجل المخاطر وخطة المعالجة





مساحة عمل الضوابط الموحدة FIG 05



غرفة التدقيق وحوكمة المستندات FIG 06

// 05

## قدرات المنصة

سلوك مطبق ومختبر في المنصة اليوم — ليست خارطة طريق ولا ادعاءات تسويقية.

|                                                                                                                                                        |                                                                                                                                                            |
|--------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>عزل المستأجرين تصميمياً</b><br>كل استعمال مقيد بحدود المنشأة من جهة الخادم؛ وتُعاد فلترة السجلات المرتبطة حتى لا تعبر أي شاشة حدود مستأجر آخر.      | <b>صلاحيات تُفرض من الخادم</b><br>تُستمد الصلاحيات من عضوية قاعدة البيانات في كل طلب؛ ويُتجاهل أي دور يدّعيه العميل مع تسجيل محاولات الرفض في سجل التدقيق. |
| <b>سجل تدقيق ضمن نفس المعاملة</b><br>كل إنشاء وتعديل واعتماد وتوليد وتصدير يكتب سطر التدقيق داخل نفس معاملة قاعدة البيانات مع التغيير ذاته.            | <b>محرك تقييم حتمي</b><br>جاهزية الضوابط وخطورة الفجوات وكفاية الأدلة تُحسب بمحرك حتمي مُختبَر — نفس المدخلات تعطي نفس الأحكام دائماً.                     |
| <b>بوابات أدلة مغلقة افتراضياً</b><br>لا يصبح الدليل مؤهلاً للتدقيق إلا بعد اجتياز العزل وفحص البرمجيات الخبيثة والإسناد المصدري وقبول المراجع جميعاً. | <b>مركز معايير واعٍ بالتخصيص</b><br>مراجع الأطر بيانات وصفية فقط حيث يقتضي الترخيص؛ ولا يُخزّن أو يُستنسخ نص المعايير المقيدة أبداً.                       |
| <b>واجهة ثنائية اللغة عربية أولاً</b><br>مساحتا عمل كاملتان بالعربية RTL والإنجليزية بنظام تصميم محكوم واحد ومفردات حالات معزّية من الطرف إلى الطرف.   | <b>مصنع مستندات محكوم</b><br>تُولّد حزم أدلة التدقيق كوثائق Word ثنائية اللغة بإشعارات مراجعة بشرية إلزامية ونطاق أمين لصلاحيات المُولّد.                  |

// 06

## التحليلات البصرية

المخاطر حسب الخطورة



الفجوات حسب حالة المراجعة



دورة حياة الأدلة



حالة معالجة المخاطر



// 07

## سجل المخاطر

مصفوفة المخاطر (الاحتمالية x الأثر)

| L \ I | 1 | 2 | 3 | 4 | 5 |
|-------|---|---|---|---|---|
| 5     | 1 |   | 1 |   |   |
| 4     |   |   |   | 1 | 1 |
| 3     |   |   | 1 | 2 |   |
| 2     |   | 1 |   | 1 | 1 |
| 1     | 1 |   |   |   | 1 |

الصفوف: الاحتمالية من 1 إلى 5 · الأعمدة: الأثر من 1 إلى 5 · قيمة الخلية عدد المخاطر

| المخاطرة                                | الاحتمالية x الأثر | المستوى | المتبقية | الحالة | المالك      |
|-----------------------------------------|--------------------|---------|----------|--------|-------------|
| Exfiltration of sensitive customer data | 4x5                | حرج     | عالي     | مفتوحة | Omar Haddad |

| المالك      | الحالة       | المتبقية | المستوى | الاحتمالية × الأثر | المخاطرة                                                |
|-------------|--------------|----------|---------|--------------------|---------------------------------------------------------|
| Omar Haddad | مفتوحة       | عالي     | عالي    | 4×4                | Critical systems missing security patches               |
| Omar Haddad | قيد المعالجة | متوسط    | عالي    | 5×3                | Phishing campaigns targeting employees                  |
| Omar Haddad | مفتوحة       | متوسط    | متوسط   | 3×4                | Concentration risk on a single cloud provider           |
| Omar Haddad | مفتوحة       | متوسط    | عالي    | 3×4                | Excessive privileged access persists after role changes |
| Omar Haddad | مفتوحة       | متوسط    | عالي    | 2×5                | Insider misuse of privileged access                     |
| Omar Haddad | قيد المعالجة | منخفض    | متوسط   | 3×3                | Security configuration drift from the approved baseline |
| Omar Haddad | قيد المعالجة | منخفض    | متوسط   | 2×4                | Backup restoration failure when recovery is required    |

// 08

## سجل الفجوات

| المراجع     | النتيجة | المستوى | الحالة       | الإطار     | الفجوة                                                         |
|-------------|---------|---------|--------------|------------|----------------------------------------------------------------|
| Maya Rahman | 10/100  | عالي    | معمتدة       | UC-RES-001 | Backup restoration evidence gap candidate                      |
| غير محدد    | 55/100  | منخفض   | مسودة        | UC-GOV-001 | Security awareness policy communication evidence gap candidate |
| غير محدد    | 20/100  | عالي    | مسودة        | UC-IAM-001 | Joiner, mover, and leaver process gap candidate                |
| Maya Rahman | 35/100  | متوسط   | قيد المراجعة | UC-VRM-001 | Mid-tier vendor assessment coverage gap candidate              |
| Maya Rahman | 5/100   | حرج     | قيد المراجعة | UC-IAM-001 | Privileged session logging and monitoring gap candidate        |
| Maya Rahman | 0/100   | عالي    | قيد المراجعة | UC-IAM-001 | Identity and access management readiness gap candidate         |
| Maya Rahman | 45/100  | متوسط   | مرفوض        | UC-GOV-001 | Cryptographic key management standard gap candidate            |

// 09

## خزنة الأدلة

| الانتهاء   | التصنيف | التخزين / الفحص                  | القرار               | الحالة       | العنوان                                             |
|------------|---------|----------------------------------|----------------------|--------------|-----------------------------------------------------|
| 02-06-2027 | داخلي   | pending storage / بانتظار القرار | يتطلب سياقاً إضافياً | قيد المراجعة | Managed Security Operations Provider Attestation    |
| 31-12-2026 | سري     | pending storage / بانتظار القرار | بانتظار القرار       | مرفوع        | Q2 Multi-Factor Authentication Configuration Report |
| 30-09-2026 | سري     | pending storage / بانتظار القرار | بانتظار القرار       | قيد المراجعة | Q1 Privileged Access Review Record                  |
| 31-03-2026 | داخلي   | pending storage / بانتظار القرار | مقبول                | منتهي        | Risk Register Extract 2025                          |
| 10-05-2027 | داخلي   | pending storage / بانتظار القرار | مقبول                | مقبول        | Annual Cybersecurity Policy Review Record           |
| 30-11-2026 | سري     | pending storage / بانتظار القرار | مرفوض                | مرفوض        | H1 Backup Restoration Test Report                   |

// 10

## غرفة التدقيق وحوكمة المستندات

### غرف التدقيق

| العنوان                                             | النطاق                                                                                                            | الحالة      | الجاهزية | المراجع     |
|-----------------------------------------------------|-------------------------------------------------------------------------------------------------------------------|-------------|----------|-------------|
| Identity and Access Management Audit Readiness Room | Privileged identity and access review evidence package covering the selected .framework metadata                  | جمع الأدلة  | محدودة   | Maya Rahman |
| Central Bank Cybersecurity Framework Readiness Room | SAMA CSF compliance readiness for critical financial systems with metadata-only .framework references             | جمع الأدلة  | محدودة   | Maya Rahman |
| Annual Essential Cybersecurity Controls Audit Room  | Annual internal assessment of the essential cybersecurity controls scope with .metadata-only framework references | قيد التخطيط | محدودة   | Maya Rahman |

### مسودات السياسات

| العنوان                     | نوع السياسة           | الحالة       | المراجع     |
|-----------------------------|-----------------------|--------------|-------------|
| Access Control Policy Draft | access control policy | قيد المراجعة | Maya Rahman |

### المستندات المولدة

| العنوان                     | نوع المستند                 | الحالة       | التصنيف | التوليد          | اللغة |
|-----------------------------|-----------------------------|--------------|---------|------------------|-------|
| Audit Evidence Package      | docx audit evidence package | قيد المراجعة | سري     | 2026-09-19 11:51 | EN    |
| Audit Evidence Package      | docx audit evidence package | قيد المراجعة | سري     | 2026-09-19 11:43 | AR    |
| Audit Evidence Package      | docx audit evidence package | قيد المراجعة | سري     | 2026-09-19 11:45 | EN    |
| Audit Evidence Package      | docx audit evidence package | قيد المراجعة | سري     | 2026-09-19 11:43 | EN    |
| Audit Evidence Package      | docx audit evidence package | قيد المراجعة | سري     | 2026-09-19 11:45 | AR    |
| Access Control Policy Draft | docx policy                 | قيد المراجعة | داخلي   | 2026-09-19 08:50 | –     |

// 11

## الموردون وتقويم الامثال

### سجل مخاطر الموردين

| المنشأة                                     | فئة الخدمة                   | الأهمية | حالة التقييم | المخاطر المتبقية | المالك        |
|---------------------------------------------|------------------------------|---------|--------------|------------------|---------------|
| Datacenter Colocation Provider              | Infrastructure hosting       | متوسط   | لم يبدأ      | متوسط            | Omar Haddad   |
| Managed Security Operations Center Provider | Security monitoring services | عالي    | معتمدة       | متوسط            | Noura AlFahad |
| Cloud Identity Provider                     | Identity platform            | حرج     | قيد المراجعة | متوسط            | Omar Haddad   |

### تقويم الامثال

| العنوان                                                          | نوع الحدث    | الحالة       | الاستحقاق  | المالك        |
|------------------------------------------------------------------|--------------|--------------|------------|---------------|
| Quarterly Privileged Access Review                               | مراجعة ضابط  | مستحق قريباً | 30-06-2026 | Omar Haddad   |
| H2 Security Awareness Policy Communication                       | مراجعة سياسة | مكتملة       | 15-07-2026 | Omar Haddad   |
| Quarterly Central Bank Cybersecurity Framework Compliance Report | تقرير تنظيمي | مستحق قريباً | 30-09-2026 | Noura AlFahad |
| Annual Essential Cybersecurity Controls Self-Assessment          | تقييم إطار   | مجدول        | 15-10-2026 | Omar Haddad   |

| العنوان                                            | نوع الحدث       | الحالة | الاستحقاق  | المالك        |
|----------------------------------------------------|-----------------|--------|------------|---------------|
| Annual Managed Security Operations Provider Review | مراجعة مورد     | مجدول  | 31-10-2026 | Noura AlFahad |
| Annual Business Continuity and Recovery Exercise   | تمرين استمرارية | مجدول  | 15-11-2026 | Omar Haddad   |

// 12

## سجل وحدات المنصة

| الوحدة              | الحالة | الدور المالك      | السجلات | الإجراء التالي                                                   |
|---------------------|--------|-------------------|---------|------------------------------------------------------------------|
| Standards Hub       | نشطة   | grc manager       | 17      | .Review metadata packs and import provenance                     |
| Assessment Studio   | نشطة   | grc manager       | 7       | .Convert deterministic findings into reviewed gap decisions      |
| Gap Register        | نشطة   | grc manager       | 7       | .Approve or reject draft gap candidates                          |
| Risk Register       | نشطة   | grc manager       | 12      | .Confirm treatment state and residual risk                       |
| Remediation Planner | نشطة   | control owner     | 1       | .Complete due tasks and refresh evidence links                   |
| Evidence Vault      | نشطة   | evidence reviewer | 6       | Keep metadata review separate from audit evidence<br>.acceptance |
| Audit Room          | نشطة   | auditor           | 3       | .Prepare evidence packages behind export approval gates          |
| Policy Factory      | نشطة   | grc manager       | 1       | .Route generated drafts through authorized review                |
| Document Factory    | نشطة   | grc manager       | 6       | .Maintain document metadata and approval state                   |
| Vendor Risk         | نشطة   | grc manager       | 3       | .Review critical vendors and linked framework evidence           |
| Compliance Calendar | نشطة   | control owner     | 6       | .Track review due dates and regulator-facing milestones          |
| Administration      | نشطة   | tenant admin      | 3       | .Review tenant memberships, roles, and least privilege           |
| Executive Dashboard | نشطة   | executive viewer  | 16      | .Monitor risk, remediation, and audit readiness trends           |

// 13

## الأطر ضمن النطاق

| الإطار        | الإصدار       | الولاية القضائية | الترخيص | سياسة الاستخدام    |
|---------------|---------------|------------------|---------|--------------------|
| CIS-CONTROLS  | 8.1           | Global           | عام     | تتطلب مراجعة بشرية |
| DORA          | metadata-2026 | European Union   | عام     | تتطلب مراجعة بشرية |
| GDPR          | metadata-2026 | European Union   | عام     | تتطلب مراجعة بشرية |
| ISO-22301     | metadata-2026 | International    | مقيد    | بيانات وصفية فقط   |
| ISO-31000     | metadata-2026 | International    | مقيد    | بيانات وصفية فقط   |
| ISO-IEC-27001 | 2022          | International    | مقيد    | بيانات وصفية فقط   |
| ISO-IEC-27002 | 2022          | International    | مقيد    | بيانات وصفية فقط   |
| ISO-IEC-27005 | metadata-2026 | International    | مقيد    | بيانات وصفية فقط   |
| ISO-IEC-27701 | metadata-2026 | International    | مقيد    | بيانات وصفية فقط   |
| NCA-CCC       | metadata-2026 | Saudi Arabia     | عام     | تتطلب مراجعة بشرية |
| NCA-DCC       | metadata-2026 | Saudi Arabia     | عام     | تتطلب مراجعة بشرية |
| NCA-ECC       | 2024-2        | Saudi Arabia     | عام     | تتطلب مراجعة بشرية |
| NIS2          | metadata-2026 | European Union   | عام     | تتطلب مراجعة بشرية |

| الإطار   | الإصدار       | الولاية القضائية | الترخيص | سياسة الاستخدام    |
|----------|---------------|------------------|---------|--------------------|
| NIST-CSF | 2.0           | United States    | عام     | تتطلب مراجعة بشرية |
| PCI-DSS  | 4.0.1         | Global           | عام     | تتطلب مراجعة بشرية |
| SAMA-CSF | metadata-2026 | Saudi Arabia     | عام     | تتطلب مراجعة بشرية |
| SOC2     | metadata-2026 | United States    | عام     | تتطلب مراجعة بشرية |

// 14

الملحق أ — تفاصيل الضوابط والأدلة

UC-IAM-001 Identity and Access Management

العائلة: Access Control
حالة التطبيق:
مطبق جزئيا

روابط الأطر

| الإطار             | المرجع            | الثقة              |
|--------------------|-------------------|--------------------|
| NCA-ECC 2-2024     | NCA-ECC-IAM-META  | قوية               |
| ISO-IEC-27001 2022 | ISO27001-IAM-META | تتطلب مراجعة يدوية |

الأدلة

| العنوان                                             | الحالة       | القرار         | أهلية التدقيق        | التصنيف |
|-----------------------------------------------------|--------------|----------------|----------------------|---------|
| Q1 Privileged Access Review Record                  | قيد المراجعة | بانتظار القرار | غير مؤهل كدليل تدقيق | سري     |
| Q2 Multi-Factor Authentication Configuration Report | مرفوع        | بانتظار القرار | غير مؤهل كدليل تدقيق | سري     |

الفجوة Privileged access review evidence lacks approval • الحالة: مفتوحة • المستوى: عالي
المعالجة Approve privileged access review evidence • الحالة: قيد التنفيذ • الأولوية: عالي
المخاطرة Excessive privileged access persists after role changes • المستوى: عالي • المتبقية: متوسط

UC-GOV-001 Cybersecurity Policy Governance

العائلة: Governance
حالة التطبيق:
مطبق

روابط الأطر

| الإطار                      | المرجع                        | الثقة              |
|-----------------------------|-------------------------------|--------------------|
| NIST-CSF 2.0                | NIST-CSF-FOUNDATION-META      | جزئية              |
| CIS-CONTROLS 8.1            | CIS-CONTROLS-FOUNDATION-META  | جزئية              |
| SOC2 metadata-2026          | SOC2-FOUNDATION-META          | جزئية              |
| PCI-DSS 4.0.1               | PCI-DSS-FOUNDATION-META       | جزئية              |
| ISO-IEC-27002 2022          | ISO-IEC-27002-FOUNDATION-META | تتطلب مراجعة يدوية |
| ISO-IEC-27701 metadata-2026 | ISO-IEC-27701-FOUNDATION-META | تتطلب مراجعة يدوية |

الأدلة

| العنوان                                   | الحالة | القرار | أهلية التدقيق        | التصنيف |
|-------------------------------------------|--------|--------|----------------------|---------|
| Annual Cybersecurity Policy Review Record | مقبول  | مقبول  | غير مؤهل كدليل تدقيق | داخلي   |

UC-RISK-001 Enterprise Cyber Risk Management

العائلة: Risk Management حالة التطبيق: مطبق

روابط الأطر

| الثقة              | المرجع                        | الإطار                      |
|--------------------|-------------------------------|-----------------------------|
| جزئية              | NCA-DCC-FOUNDATION-META       | NCA-DCC metadata-2026       |
| جزئية              | SAMA-CSF-FOUNDATION-META      | SAMA-CSF metadata-2026      |
| جزئية              | GDPR-FOUNDATION-META          | GDPR metadata-2026          |
| جزئية              | DORA-FOUNDATION-META          | DORA metadata-2026          |
| جزئية              | NIS2-FOUNDATION-META          | NIS2 metadata-2026          |
| تتطلب مراجعة يدوية | ISO-IEC-27005-FOUNDATION-META | ISO-IEC-27005 metadata-2026 |
| تتطلب مراجعة يدوية | ISO-31000-FOUNDATION-META     | ISO-31000 metadata-2026     |
| جزئية              | NCA-CCC-FOUNDATION-META       | NCA-CCC metadata-2026       |

الأدلة

| العنوان                    | الحالة | القرار | أهلية التدقيق        | التصنيف |
|----------------------------|--------|--------|----------------------|---------|
| Risk Register Extract 2025 | منتهى  | مقبول  | غير مؤهل كدليل تدقيق | داخلي   |

UC-VRM-001 Vendor Security Risk Management

العائلة: Third Party Risk حالة التطبيق: مطبق جزئياً

الأدلة

| العنوان                                          | الحالة       | القرار               | أهلية التدقيق        | التصنيف |
|--------------------------------------------------|--------------|----------------------|----------------------|---------|
| Managed Security Operations Provider Attestation | قيد المراجعة | يتطلب سياقاً إضافياً | غير مؤهل كدليل تدقيق | داخلي   |

المخاطرة Prolonged regional datacenter outage • المستوى: عالي • المتبقية: متوسط

UC-RES-001 Resilience and Continuity Planning

العائلة: Resilience حالة التطبيق: مطبق جزئياً

روابط الأطر

| الثقة              | المرجع                    | الإطار                  |
|--------------------|---------------------------|-------------------------|
| تتطلب مراجعة يدوية | ISO-22301-FOUNDATION-META | ISO-22301 metadata-2026 |

الأدلة

| العنوان                           | الحالة | القرار | أهلية التدقيق        | التصنيف |
|-----------------------------------|--------|--------|----------------------|---------|
| H1 Backup Restoration Test Report | مرفوض  | مرفوض  | غير مؤهل كدليل تدقيق | سري     |

الفجوة Backup restoration test evidence is incomplete • الحالة: قيد التنفيذ • المستوى: عالي

المخاطرة Prolonged regional datacenter outage • المستوى: عالي • المتبقية: متوسط

UC-AUD-001 Audit Readiness Management

العائلة: Audit حالة التطبيق: غير مطبق

الأدلة

لا توجد أدلة مرتبطة بعد.